WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Broken Access-Control Logic & CSRF in Post Deletion

Finding NVP-015 · **Low**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-015
Vulnerability	Broken Access-Control Logic & CSRF in Post Deletion
Severity	**Low**
CVSS 4.0	4.8 `CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:A/VC:N/VI:H/VA:L/SC:N/SI:N/SA:N`
CWE	CWE-670 (Always-Incorrect Control Flow); CWE-352 (CSRF)
OWASP	A04:2021 Insecure Design
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

The delete check uses assignment instead of comparison — if($_GET["action"]="del") — so it is always true; merely requesting manage-posts.php?pid=N soft-deletes post N. Combined with the lack of CSRF protection and GET-based deletion, this enables forced/cross-site deletions.

2. Affected Target

Affected URL	http://localhost/newsportal/newsportal/admin/manage-posts.php
Affected parameter	pid, action (GET)
Affected role	Authenticated admin/sub-admin (victim)
Authentication	Login required

3. Technical Description

admin/manage-posts.php:11 uses a single "=" (assignment) rather than "==", so the branch always executes. Any GET with a pid triggers "update tblposts set Is_Active=0 where id='$postid'". There is no CSRF token and the action is a GET, so deletion can be forced via a cross-site <img>/link against a logged-in admin.

4. Root Cause Analysis

```
admin/manage-posts.php:11-14 — if($_GET['action']='del'){ $postid=intval($_GET['pid']);
mysqli_query($con,"update tblposts set Is_Active=0 where id='$postid'"); }
```

5. Preconditions

A logged-in admin/sub-admin; for cross-site abuse, the victim loads attacker content.

6. Proof of Concept — Step-by-Step Reproduction

1. As an authenticated user, request /admin/manage-posts.php?pid=14 (note: no action parameter needed).
2. The post is soft-deleted (Is_Active=0) because the condition is always true.
3. Because it is a GET with no CSRF token, a cross-site <img src=...pid=14> forces the same deletion on a logged-in admin.

7. HTTP Request Evidence

```
GET /newsportal/newsportal/admin/manage-posts.php?pid=14 HTTP/1.1
Host: localhost
Cookie: PHPSESSID=<admin>
```

8. HTTP Response Evidence

```
HTTP/1.1 200 OK — post id=14 Is_Active set to 0 (removed from public listing).
```

9. Proof of Concept — Visual Evidence

> **Evidence note:** Confirmed from source (assignment bug) and behaviour; demonstrated on the lab test post (id=14), which is reversible (Is_Active toggle).

10. Actual Security Impact

Unintended and cross-site-forced removal of posts from the public site; a logic defect that also weakens integrity/availability of content.

Exploitation complexity	Low to trigger directly; Medium for cross-site (needs victim session + interaction).
Realistic attack scenario	An attacker tricks a logged-in admin into loading a page that silently deletes posts; or any stray request removes content.

11. Remediation Recommendations

Use comparison (===) and require POST with a CSRF token for deletions; implement proper confirmation and authorization; prefer soft-delete with an audit trail.

Secure code example

```
if ($_SERVER['REQUEST_METHOD']==='POST' && hash_equals($_SESSION['csrf'],$_POST['csrf']) &&
$_POST['action']==='del') { /* delete by bound pid */ }
```

12. Retesting Procedure

Request the URL without action; a fixed system does not delete and requires a valid POST+token.

13. References

- CWE-670
- CWE-352
- OWASP A04:2021

14. Conclusion

Confirmed always-true delete logic + CSRF on a GET deletion. Verified from source and on reversible test data.